

Role-based access model — Halden Distribution Ltd.

Purpose: the single document that says what access each role gets, and therefore what the automated joiner-mover-leaver process will grant and remove. **Owner:** IT (Muhammad Ibrahim Akmal) · **Approvers:** department heads (access is a business decision, not an IT decision) · **Review:** quarterly, plus on every role change **Enforcement:** `configs/role-matrix.csv` is the machine-readable version of this document. IT does not hand-grant access; changing this model is how access changes.

1. How to read this

- **Role group** (`G_...`) — who a person *is*, by department and role. This is what gets applied to a person's account.
- **Resource reached** (`DL_...`) — what that role group is allowed to *open*. Access is reached through the role group by the least-privilege model built in P1, so nobody is ever named directly on a folder.
- **Cloud/service** — the licences and applications the role receives.

If a line is wrong, the fix is a change to this model, approved by the department head — not a one-off group edit. A one-off edit is exactly how an organisation loses track of who can read what.

2. The model

Department	Role	Role group	Reaches (resources)	Cloud / services
Management	Any	<code>G_Management</code> , <code>G_AllStaff</code>	Company (read); Finance, HR, Sales, Operations (read-only)	Microsoft 365, GLPI, BookStack
Finance	Any	<code>G_Finance_Staff</code> , <code>G_AllStaff</code>	Finance (read/write); Finance read-only; Company (read)	Microsoft 365, GLPI, BookStack
HR	Any	<code>G_HR_Staff</code> , <code>G_AllStaff</code>	HR (read/write); Company (read)	Microsoft 365, GLPI, BookStack
Sales	Any	<code>G_Sales_Staff</code> , <code>G_AllStaff</code>	Sales (read/write); Company (read)	Microsoft 365, GLPI, BookStack
Operations / Warehouse	Any	<code>G_Operations_Staff</code> , <code>G_AllStaff</code>	Operations (read/write); Company (read)	Microsoft 365, GLPI, BookStack
IT	Systems Administrator	<code>G_IT_Staff</code> , <code>G_IT_LinuxAdmins</code> , <code>G_AllStaff</code>	Company and all departments (read); Linux servers by AD group	Microsoft 365, GLPI, BookStack, LNK01 SSH and sudo

Department	Role	Role group	Reaches (resources)	Cloud / services
IT	IT Support Officer and other IT titles	G_IT_Staff , G_AllStaff	Company and all departments (read)	Microsoft 365, GLPI, BookStack

Notes on the deliberate choices

- **IT holds read access for support only.** IT does not hold write access to departmental content by design. Write access to a business folder is granted only by putting the person in that department's role group. This is what makes "IT cannot quietly change the accounts" a property of the design rather than a promise.
- **Management holds read-only** across departments so directors can review, but cannot alter departmental content.
- **G_IT_LinuxAdmins is a separate, narrower grant** than IT membership: an IT Support Officer is not automatically able to log in to the Linux server and run commands as root. That separation is the difference between "works in IT" and "administers the servers".
- **G_AllStaff is in every row on purpose.** It grants company-wide reading and the self-service home drive, nothing more.

3. What the automation will and will not touch

It will	It will not
Add the role groups in the table above	Touch any group that is not in this model (for example a project distribution list)
Remove role groups from this model that no longer match the person's role	Remove a separate, individually approved grant
Set the person's department, job title and manager from the HR record	Change anything for the protected accounts (service accounts, break-glass, built-in)
Move the account to the correct department area of the directory	Delete an account (leavers are disabled and retained for 90 days)

Groups outside this model are **reported** during a review, not removed automatically. That is deliberate: an automated tool should not silently revoke an access nobody asked it to manage.

4. How the model is kept honest

1. **The file is the source for every JML run** — `configs/role-matrix.csv` . If a role is not in the file, the engine will not invent access for it; it reports it instead.
1. **The quarterly access review** (`docs/runbooks/run-the-access-review.md`) compares what people actually have against this model and lists the differences for the department heads.
1. **Any difference is an action with an owner and a due date**, not a note in an email.

5. Approvals

Each department head approves their row(s). An unapproved row is removed at the next review.

Department	Approver name	Role	Date	Signature / approval
Management		Managing Director		
Finance		Finance Director		
HR		HR Director		
Sales		Sales Director		
Operations / Warehouse		Operations Director		
IT		IT Manager		

Status: unsigned. The model is implemented in the lab; the signature column is deliberately left blank until the review actually takes place.

Lab note: Halden Distribution Ltd. is a **fictional company** and the staff data behind these roles is **synthetic** (invented names, no real personal data). This model is a real design applied to a lab, not a real company's approved access list.